

SALDIRI T RLER 

Ke if (Reconnaissance): Saldırıdan  nce hedef hakkında bilgi toplama a amasıdır.  rne in Nmap ile a ık portların taranması. Loglarda  ok sayıda ba lantı denemesi veya a  taraması olarak g r lebilir. Analist i in  nemlidir   nk  saldırının en erken belirtisidir.

Ge en Haftaki Lab ile Ba lantı:

Ge en hafta Windows ve Ubuntu makinelerinin a  yapılarını incelerken ipconfig, ip a ve ping komutlarını kullandım. Bu komutlarla makinelerin IP adreslerini ve birbirleriyle olan ba lantılarını kontrol ettim. Bu  alı malar do rudan bir ke if saldırısı de ildi ancak saldırganın hedef hakkında IP adresi ve a  bilgisi toplamasıyla benzer bir mantı a sahipti.

Saldırgan a ısından: Bu bilgileri  rendikten sonra hangi sisteme ve hangi servise saldıracağını belirleyebilir.

Brute Force: Bir hesabın parolasını bulmak i in  ok sayıda parola denemesidir. Linux'ta auth.log i erisindeki Failed password, Windows'ta Event ID 4625 kayıtları g r lebilir.  ok sayıda ba arısız giri  ve ardından ba arılı giri  olması saldırının ba arılı olmu  olabilece ini d      r r.

Ge en Haftaki Lab ile Ba lantı:

Ge en hafta SSH ba lantısı sırasında ba arısız giri  denemeleri yaptım ve Ubuntu'da /var/log/auth.log i erisinde Failed password kayıtlarını inceledim. Windows tarafında ise ba arısız giri lerin Event ID 4625 ile kaydedildi ini g rd m. Bu kayıtlar kontroll  ba arısız giri  denemeleriydi. Ger ek bir brute force saldırısında aynı kullanıcıya kısa s rede  ok sayıda parola denenmesi benzer log kayıtları olu turabilir.

Saldırgan a ısından: Ama  do ru parolayı bulup hesaba eri mektir.

Password Spraying: Aynı veya az sayıda yaygın parolanın bir ok farklı kullanıcı hesabında denenmesidir. Loglarda kısa s rede farklı kullanıcılar i in  ok sayıda 4625 veya ba arısız SSH kaydı g r lmesi   phelidir. Analist, saldırganın tek bir hesabı mı yoksa bir ok hesabı mı hedefledi ine bakar.

Brute Force	Password Spraying
Genellikle tek kullanıcı	Birden fazla kullanıcı
�ok sayıda parola	Genellikle aynı/yaygın parola
admin hesabına 100 parola	100 hesaba Password123
Aynı kullanıcıya �ok sayıda ba�arısız giri�	�ok sayıda kullanıcıya ba�arısız giri�

Phishing: Kullanıcıyı kandırarak parola veya hassas bilgilerini ele geçirmeyi amaçlayan sosyal mühendislik saldırısıdır. Örneğin sahte bir giriş sayfasına yönlendiren e-posta gönderilmesi. İlk aşamada işletim sistemi loglarında doğrudan görünmeyebilir; ancak DNS, web/proxy, e-posta ve sonrasında oluşan process/network loglarında iz bırakabilir. Analist için önemlidir çünkü hesap ele geçirme veya zararlı yazılım çalıştırmanın başlangıcı olabilir.

MITM (Man-in-the-Middle): Saldırganın iki taraf arasındaki iletişimin arasına girerek trafiği dinlemesi, değiştirmesi veya yönlendirmesidir. Örneğin sahte Wi-Fi veya ARP spoofing kullanılabilir. Loglarda beklenmeyen ARP/MAC değişiklikleri, ağ geçidi değişiklikleri, TLS uyarıları veya şüpheli network bağlantıları görülebilir. Analist için önemlidir çünkü iletişimin ve hassas bilgilerin saldırgan tarafından ele geçirilmesine yol açabilir.

- **ARP Spoofing:** Saldırganın ARP protokolünü manipüle ederek kendi MAC adresini başka bir cihazın IP adresiyle ilişkilendirmesidir. Amaç, ağ trafiğini kendi üzerinden geçirmek ve MITM saldırısı gerçekleştirmektir. Analist, beklenmeyen IP-MAC eşleşmelerini ve ARP değişikliklerini inceler.
- **ARP (Address Resolution Protocol),** yerel ağda bir IP adresinin hangi MAC adresine ait olduğunu bulmak için kullanılır.

Geçen Haftaki Lab ile Bağlantı:

Geçen hafta Windows ve Ubuntu makinelerini aynı ağ üzerinde çalıştırarak aralarındaki iletişimi inceledim. ping, IP adresleri ve ağ arayüzleri üzerinden iki makinenin birbirine nasıl eriştiğini kontrol ettim.

Bu çalışma doğrudan bir MITM saldırısı değildi. Ancak iki sistem arasındaki iletişimin nasıl gerçekleştiğini anlamam, MITM saldırısında saldırganın bu iletişimin arasına girerek trafiği kendi üzerinden geçirmesi mantığını anlamamı sağladı.

Saldırgan açısından: İletişimi dinlemek veya değiştirmek amaçlanır.

Hizmet Reddi(DoS/DDoS): DoS (Denial of Service), bir sistemi veya hizmeti aşırı istek ya da trafik göndererek kullanılamaz hale getirmeyi amaçlayan saldırıdır. **DDoS (Distributed Denial of Service)** aynı saldırının çok sayıda farklı kaynaktan gerçekleştirilmesidir. Loglarda aşırı bağlantı/istek sayısı, trafik artışı, timeout ve çok sayıda kaynak IP görülebilir. Analist için önemlidir çünkü sistemin kullanılabilirliğini bozarak hizmet kesintisine neden olabilir.

Yanal Hareket (Lateral Movement): Saldırganın bir sistemi ele geçirdikten sonra ağdaki diğer sistemlere veya hesaplara erişmeye çalışmasıdır. Örneğin ele geçirilen bir Windows makinesinden Ubuntu sunucusuna SSH bağlantısı kurulması. Linux'ta SSH bağlantıları /var/log/auth.log içerisinde görülebilir; Windows tarafında ağ bağlantıları için Sysmon Event ID 3 incelenebilir. Analist için önemlidir çünkü saldırganın ağ içerisinde daha değerli sistemlere ilerlediğini gösterebilir.

- **Initial Access:** Sisteme gir.
- **Lateral Movement:** Başka sistemlere geç.

Privilege Escalation: Saldırganın sahip olduğu yetkileri artırarak daha yüksek ayrıcalıklı bir kullanıcı veya işlem elde etmesidir. Örneğin Linux'ta normal bir kullanıcının sudo kullanarak root yetkisiyle komut çalıştırması. Linux'ta auth.log içerisindeki sudo kayıtları, Windows'ta ise yönetici yetkileri, UAC, grup değişiklikleri ve process kayıtları incelenebilir. Analist için önemlidir çünkü saldırganın sistem üzerindeki kontrol seviyesini ciddi şekilde artırır.

Geçen Haftaki Lab ile Bağlantı:

Geçen hafta Ubuntu'da, “sudo whoami” komutunu çalıştırdım ve sonucunda “root” çıktısını aldım. Daha sonra /var/log/auth.log içerisinde sudo işleminin kaydını inceledim ve hangi kullanıcının hangi komutu çalıştırdığını gördüm.

Bu işlem benim tarafımdan kontrollü olarak gerçekleştirilen bir yönetim işlemiydi. Gerçek bir saldırıda ise saldırganın düşük yetkili bir hesaptan root veya Administrator seviyesine çıkması privilege escalation olarak adlandırılır.

Saldırgan açısından: Daha yüksek yetkiler elde ederek sistem üzerinde daha fazla kontrol sağlamak amaçlanır.

Persistence (Kalıcılık): Saldırganın sisteme tekrar erişebilmesini sağlamak için bıraktığı mekanizmalardır. Örneğin yeni bir kullanıcı hesabı oluşturup bu hesabı yönetici grubuna eklemek, SSH anahtarı eklemek veya zamanlanmış görev oluşturmak. Loglarda kullanıcı oluşturma, grup değişiklikleri, servis/task oluşturma gibi olaylar incelenebilir. Analist için önemlidir çünkü saldırganın ilk erişimi kaybolursa bile sisteme yeniden girmesine olanak sağlayabilir.

Geçen Haftaki Lab ile Bağlantı:

Geçen hafta Windows'ta kullanıcı ve grup yapısını incelerken Administrator, Administrators ve Users yapılarını öğrendim. Ayrıca yeni bir yönetici hesabı oluşturulmasının sistem açısından ne anlama geldiğini inceledim.

Normal bir yönetim işlemi olarak oluşturulan bir hesap ile saldırganın kendisi için oluşturduğu hesap aynı şey değildir. Ancak saldırgan sisteme girdikten sonra yeni bir kullanıcı oluşturup bu kullanıcıya yönetici yetkisi verirse, mevcut oturumu sonlandırılrsa bile tekrar giriş yapabilmek için bir yol bırakmış olur. Bu nedenle böyle bir işlem persistence olarak değerlendirilebilir.

Saldırgan açısından: İlk erişimini kaybetse bile sisteme tekrar girebilmek amaçlanır.

Kısaca benim geçen haftaki çalışmalarım ile bağlantısı

- **Keşif:** ipconfig, ip a, ping
- **Brute Force:** Failed password ve 4625
- **Password Spraying:** Başarısız girişlerin farklı kullanıcılar üzerinden değerlendirilmesi
- **Phishing:** Ele geçirilen parolayla oluşabilecek Accepted password ve 4624
- **MITM:** Windows ↔ Ubuntu ağ iletişiminin incelenmesi
- **DoS/DDoS:** ping ve ağ erişilebilirliği çalışması

- **Lateral Movement:** Windows → Ubuntu SSH bağlantısı
- **Privilege Escalation:** sudo whoami → root
- **Persistence:** Yeni kullanıcı ve yönetici yetkileri konusunun incelenmesi

ZARARLI YAZILIM TÜRLERİ

1. Virüs (Virus)

Kendisini başka bir dosya veya programa ekleyerek, dosya çalıştırıldığında yayılabilen zararlı yazılımdır.

Örnek: Bir .exe dosyasına bulaşarak dosya çalıştırıldığında başka dosyalara yayılması.

Analist neden önemser? Dosya ve process değişikliklerini, zararlı yazılımın hangi dosyalara bulaştığını ve yayılıp yayılmadığını takip etmek gerekir.

2. Solucan (Worm)

Başka bir dosyaya ihtiyaç duymadan kendi kendine çoğalabilen ve özellikle ağ üzerinden yayılabilen zararlı yazılımdır.

Örnek: Bir bilgisayardaki zafiyetten yararlanarak aynı ağdaki diğer bilgisayarlara yayılması.

Analist neden önemser? Kısa sürede çok sayıda sistemi etkileyebileceği için ağ bağlantıları ve yayılma davranışları takip edilmelidir.

3. Truva Atı (Trojan)

Kendisini yararlı veya normal bir program gibi göstererek kullanıcıyı kandıran zararlı yazılımdır.

Örnek: Ücretsiz bir program gibi görünen ancak çalıştırıldığında zararlı işlem başlatan yazılım.

Analist neden önemser? Kullanıcı tarafından normal bir program gibi çalıştırılabileceği için saldırganın sisteme ilk erişimini sağlayabilir.

4. Fidye Yazılımı (Ransomware)

Dosyaları şifreleyerek veya sistemi kullanılamaz hale getirerek kullanıcıdan fidye talep eden zararlı yazılımdır.

Örnek: Belgelerin şifrelenmesi ve dosyaların açılması için ödeme istenmesi.

Analist neden önemser? Çok sayıda dosyanın kısa sürede değiştirilmesine ve kritik sistemlerin kullanılamaz hale gelmesine neden olabilir.

5. RAT (Remote Access Trojan)

Saldırgana ele geçirilmiş bilgisayar üzerinde uzaktan kontrol sağlayan zararlı yazılımdır.

Örnek: Saldırganın RAT aracılığıyla kurban bilgisayarda komut çalıştırması.

Analist neden önemser? Saldırgana sistem üzerinde uzun süreli uzaktan kontrol sağlayabilir.

6. Rootkit

Saldırganın sistemde gizlenmesini ve yüksek yetkilerle faaliyet göstermesini sağlayan zararlı yazılım veya araç grubudur.

Örnek: Zararlı process veya dosyaların sistem araçlarında görünmesini engellemeye çalışması.

Analist neden önemser? Saldırganın faaliyetlerini gizleyebildiği için geleneksel tespit yöntemlerini zorlaştırır.

7. Dosyasız Zararlı Yazılım (Fileless Malware)

Zararlı kodun klasik bir dosya olarak diske bırakılması yerine çoğunlukla bellek üzerinde veya işletim sisteminin meşru araçları kullanılarak çalıştırıldığı zararlı yazılım türüdür.

Örnek: Windows'ta PowerShell kullanılarak zararlı kodun bellekte çalıştırılması.

Analist neden önemser? Geleneksel dosya tabanlı tespit yöntemlerini atlatabilir. Bu nedenle sadece dosyalara değil, process, komut satırı, PowerShell, DNS ve network aktivitelerine de bakılması gerekir.

CYBER KILL CHAIN

Cyber Kill Chain, Lockheed Martin tarafından geliştirilen ve siber saldırının aşamalarını anlamak için kullanılan bir modeldir. Saldırıyı tek bir olay olarak değil, birbirini takip eden aşamalar şeklinde ele alır.

1. Keşif (Reconnaissance)

Saldırganın hedef hakkında bilgi topladığı aşamadır. IP adresleri, açık portlar, çalışan servisler ve kullanıcılar araştırılabilir.

Örnek: Hedef sistemde açık portların taranması.

2. Silahlanma (Weaponization)

Saldırganın hedefte kullanacağı zararlı yazılımı veya saldırı aracını hazırladığı aşamadır.

Örnek: Belirli bir sisteme yönelik zararlı dosya hazırlanması.

3. Teslim (Delivery)

Hazırlanan zararlı içeriğin hedefe ulaştırıldığı aşamadır.

Örnek: Phishing e-postasıyla zararlı dosya veya bağlantı gönderilmesi.

4. İstismar (Exploitation)

Saldırganın sistemdeki bir zafiyetten veya kullanıcı hatasından yararlanarak saldırıyı gerçekleştirdiği aşamadır.

Örnek: Bir yazılım açığından yararlanarak sisteme erişim sağlanması.

5. Kurulum (Installation)

Saldırganın zararlı yazılımı veya erişimini sağlayacak mekanizmayı hedef sisteme yerleştirdiği aşamadır.

Örnek: RAT gibi bir zararlı yazılımın sisteme kurulması.

6. Komuta ve Kontrol (Command & Control)

Saldırganın ele geçirdiği sistemle uzaktan iletişim kurduğu aşamadır.

Örnek: Zararlı yazılımın saldırganın C2 sunucusuna bağlanması.

7. Hedefe Yönelik Eylem (Actions on Objectives)

Saldırganın sisteme girdikten sonra asıl amacını gerçekleştirdiği aşamadır.

Örnek: Veri çalmak, dosyaları şifrelemek veya sistemi kullanılamaz hale getirmek.

Analist açısından önemi

Cyber Kill Chain, analistin saldırıyı yalnızca tek bir alarm olarak değil, birbirini takip eden olaylar zinciri olarak değerlendirmesine yardımcı olur. Bir aşamada saldırgan durdurulsa bile önceki ve sonraki aşamalarda hangi faaliyetlerin gerçekleşmiş olabileceği araştırılabilir.

Kill Chain'in sınırlaması

Cyber Kill Chain saldırının genel akışını anlamak için kullanışlıdır ancak saldırganın sistem içine girdikten sonra yaptığı yetki yükseltme, kimlik bilgisi çalma, yanal hareket ve kalıcılık gibi faaliyetleri ayrıntılı şekilde sınıflandırmakta sınırlıdır.

Bu nedenle daha ayrıntılı saldırgan davranışlarını açıklamak için MITRE ATT&CK gibi modeller kullanılır.

****Geçen hafta oluşturduğum olayları Cyber Kill Chain ile karşılaştırdığımda, başarılı girişin istismar aşamasıyla kısmen ilişkilendirilebildiğini, ancak başarısız giriş ve sudo ile yetki yükseltme olaylarının modele tam olarak oturmadığını gördüm. Bunun nedeni Cyber Kill Chain'in saldırının genel yaşam döngüsünü yedi aşamada açıklaması ve sistem ele geçirildikten sonraki tüm saldırgan davranışlarını ayrıntılı olarak sınıflandırmamasıdır. Yetki yükseltme, yanıl hareket, kalıcılık ve kimlik bilgisi çalma gibi davranışları daha ayrıntılı açıklamak için MITRE ATT&CK gibi daha kapsamlı bir modele ihtiyaç vardır.**